

침해사고 대응 현장에서 배우는 의사결정

Incident Response Decision Making in the Field

서비스가 갑자기 느려졌습니다.

여러분이라면 무엇부터 확인하시겠습니까?

CPU ↑

Memory ↓

Tomcat Failure

오늘 이야기할 것은 세 가지 사고가 아닙니다.

세 가지 사고에서 우리가 내렸던 판단입니다.

CASE 01

**Service
Failure**

CASE 02

**Web Shell
Found**

CASE 03

**RDP
Access**

DECISION IS THE WORK

침해사고 대응은 선택의 연속입니다.

격리할 것인가?



더 조사할 것인가?



어디까지 침해됐다고 볼 것인가?



언제 복구할 것인가?

LIFECYCLE

DETECT → INVESTIGATE → CONTAIN → RECOVER

현장은 계속 되돌아갑니다.

새로운 증거가 나오면 판단도 다시 바뀝니다.

CASE 01

SERVICE FAILURE

"서버가 계속 죽습니다."

INITIAL EVIDENCE

처음 보이는 것은 장애에 가깝습니다.

01

**Tomcat service
failure**

02

**Available
memory ↓**

03

**Java process
terminated**

SECURITY INCIDENT? UNKNOWN

DECISION POINT 01

**이것을
보안사고로
판단할 수 있는가?**

NEW EVIDENCE

장애의 원인이 프로세스에서 보이기 시작합니다.

PROCESS	c3pool
CPU usage	HIGH
Network	ACTIVE
Pool connection	DETECTED

CRYPTOMINER CONFIRMED

DECISION POINT 02

악성 프로세스를 발견했습니다. 지금 종료하시겠습니까?

CONTAIN

프로세스 종료
서비스 안정화
확산 차단

PRESERVE

Network connection
Process tree
Command line
Memory

HYPOTHESIS UPDATED

새로운 증거가 나오면 처음의 가설도 바뀝니다.

INITIAL HYPOTHESIS

서비스 또는
애플리케이션 장애

Tomcat failure · Memory 부족 · Java 종료

REVISED HYPOTHESIS

악성 채굴 프로그램에 의한
자원 고갈

c3pool · Active network · Pool connection

가설을 지키는 것이 아니라, 증거에 맞춰 가설을 수정합니다.

CASE 02

WEB SHELL

/uploads/\n └─ aa.jsp

이 파일을 삭제하면 사고는 끝날까요?

ONE ARTIFACT

aa.jsp

mtime	2026-07-30 00:01
web shell	YES
initial access	?
attacker	?
other systems	?

FOLLOW THE EVIDENCE

하나의 파일에서 공격 행위 전체로 확장합니다.

aa.jsp

|

|— mtime

|— Access Log

| |— Source IP

| |— User-Agent

|— Additional JSP

파일 → 로그

로그 → IP

IP → 행위

행위 → 범위

DECISION POINT 03

조사는 어디까지 해야 하는가?



CORRELATION

mtime은 단서지만,
침해 시점 그 자체는 아닙니다.

2026-07-30 00:01

File timestamp

**서로 다른 증거가
같은 이야기를 하는가**

Access log · Network log · Process evidence

CASE 03

EVENT 4624

Account Name	Administrator
Logon Type	10
Status	Success

공격자일까요?

EVIDENCE ACCUMULATES

하나의 이벤트는 시나리오가 될 때 강해집니다.

- 01 4624 / Logon Type 10
- 02 RDP session
- 03 Firewall connection
- 04 PortScanner · sshcracker · RDPcheck

DECISION POINT 04

언제부터 '침해'라고 판단할 것인가?

LOW

HIGH



다만, 증거가 많다고 해서 모두 같은 공격을 설명하는 것은 아닙니다.

ONE SERVER, MULTIPLE ATTACKERS

같은 시간, 같은 서버. 같은 공격자일까?

7/28 22:14 · TRACE 01

RDP 로그인 시도

3389/TCP

Source 203.0.113.17

ATTACKER A

7/29 03:42 · TRACE 02

웹 취약점 스캔

/.env · /cgi-bin · vulnerable

URL

Source 198.51.100.42

ATTACKER B

7/29 11:07 · TRACE 03

SMB / 445 탐색

445/TCP · service probe

Source 192.0.2.88

ATTACKER C

시간만 놓고 보면 하나의 공격 흐름처럼 보일 수 있습니다.

하지만 세 흔적을 연결할 근거는 없습니다. 같은 서버에는 서로 다른 공격자의 행위가 동시에 섞일 수 있습니다.

시간적 인접성 ≠ 공격 연관성

SAME PATTERN

사건은 달라도 판단의 구조는 반복됩니다.

CASE 01

Service Failure



Process



Cryptominer

CASE 02

Web Shell



Access Log



Activity

CASE 03

Login



RDP / Network



Attack Tools

THE LOOP

사고 대응은 이 루프를 반복하는 과정입니다.



새로운 증거는 이전 판단을 강화하기도 하고, 완전히 바꾸기도 합니다.

현장의 판단은 항상 제약 속에서 이루어집니다.

시간

빠르게 다음 행동을 정해야 합니다.

서비스 연속성

분석을 위해 무조건 중단할 수는 없습니다.

증적 보존

조치 자체가 중요한 흔적을 지울 수 있습니다.

인력과 범위

모든 시스템을 무한정 조사할 수는 없습니다.

불완전한 로그

필요한 정보가 남아 있지 않은 상태에서도 판단해야 합니다.

우리가 계속 결정했던 다섯 가지

01. 지금 조치할 것인가, 더 확인할
것인가?

02. 이것을 공격이라고 판단할 수
있는가?

03. 조사 범위를 어디까지 확장할
것인가?

04. 어떤 증거를 신뢰할 것인가?

05. 언제 사고가 끝났다고 판단할 것인가?

좋은 사고 대응은 좋은 질문에서 시작됩니다.

무슨 일이 일어났는가?

언제 시작됐는가?

어디까지 영향을 받았는가?

공격자는 아직 존재하는가?

지금 가장 먼저 해야 할 일은 무엇인가?

THANK YOU · Q&A